International AI Track | Security Self-assessment

Optional supporting material. Please complete this document in English.

Team name	Centrale
Competition track	International AI Track, Topic C (Cross-border and Student Finance)
Submission date	2026-10-20

Scope and how to read this

This is a self-assessment of the BorderlessGuard prototype, which runs against a **simulated sandbox ledger**. The authors wrote it. Two inputs are not ours: three white-box audits by separate AI agents with full read access to the code (12, 11 and 8 findings: 31 in all, fixed or mitigated and regression-tested), and a blind test set written by a separate AI agent that could not read the security code. The round-3 fixes were reviewed once more by a separate AI agent on 2026-10-20 (nine points, seven fixed).

Two results estimate generalisation, one per parser: blind v2 with the rules parser, frozen in `44542f2` (**69/70 attacks blocked**, 24/30 benign English completed), and blind v2 with local Qwen2.5 7B, frozen in `5868d83` (**66/70 attacks blocked**, 26/30 benign English, 5/5 non-English). Everything measured after them is regression. State: the working tree of 2026-10-20 after commit `3b4e894`: 1379 tests pass, 7 are documented expected failures; `tests/audit`: 169 pass.

This assessment does not claim that the prototype is secure. It lists what we built, what was tested, and what remains open or unverified (Section 04). No hosted or frontier model was measured. No licensing, KYC, AML, sanctions or data-protection compliance is claimed.

01 Permission Model

- **Roles, operations and permission boundaries**

Role	Operations	Permission boundary
Customer (the student, one session per `user_id`)	Ask; attach a document; approve or reject her own pending actions with a tap or a code; cancel; read her own overview and receipts; check her receipts against her signed copy.	Sees and acts on her own accounts and payees only (`TENANT_ISOLATION`). Cannot change limits, the watchlist, the FX price or the code. Each approval is bound to the hash of the exact action.
Language model (any parser)	Propose typed intents from the customer's text.	No tool, no authority, no access to accounts, balances, IBANs or documents. Its output is validated, grounded in the customer's words and policed like any input.
Content guard	Warn about injected documents and tool output.	Advisory. No authorisation reads its output.
FX provider (simulated)	Return a price.	Untrusted. A quote is kept only if it equals the bank's reference price and the ledger issued it; it is used once.
Bank operator (stands in as a reset function)	Unlock approval by code after three wrong codes.	Never reachable from chat. In the sandbox it is a function call and the Reset demo button; there is no operator login. In the demo UI the same visitor can press Reset demo (its help text says it stands in for the operator), so the customer can clear her own lock: it is demonstrated there, not protective.
Verifier (customer or reviewer)	Run the chain check against a signed anchor.	Read-only.

The tier of an action is the highest severity among its failing rules, over a base of R2 for payments and exchanges and R3 for adding a payee. Any exception is R4.

Tier	Operation	Boundary
R0	Overview, receipts, rate quote, affordability simulation	Allowed; creates no action and does not call the policy engine
R1	Reversible actions	Defined; no action uses it
R2	Payment to a payee older than 72 h up to 1,500 EUR eq. (same-payee 24 h total included); currency purchase up to 2,500 EUR eq.	One tap. Frozen while the code lock is on
R3	Payment to a payee under 72 h old; larger amounts (up to 4,000); splitting payments; currency purchase above 2,500 EUR eq.; adding a payee; `PAYEE_VERIFICATION` (Verification of Payee) close match, no match or not available	One-time code; three wrong codes in a row freeze every approval of the customer, taps included
R4	Infeasible payment, unregistered or blocked payee, IBAN not in the registry, other tenant, reserve breach, over 4,000 EUR per payment or 5,000 EUR per day, untrusted origin, sanctions hit, invalid IBAN, look-alike payee name, off-price FX quote, `PAYEE_VERIFICATION` no match or not available when the account number comes from a document of the same request, locked approval, policy error	Denied; nothing the model or the customer says overrides it

Access surfaces. The same orchestrator and gates sit behind all three; they differ in who can reach them.

Surface	Who is the customer	Authentication	Limits
Streamlit UI	Fixed: Lina (`u_lina`)	None: local demo on `127.0.0.1`, Host allow-list	The code is shown on screen and the guided demo enters it; Reset demo, the model selector and the exchange-rate toggle rebuild the sandbox and clear the code lock
Harness CLI	`--user`: any seeded customer	None: a local process	Same orchestrator and gates
HTTP API	Any seeded customer; the one in `BG_API_USER`; or the one a per-customer token is bound to	None on loopback unless a token is set; a token is required off loopback (plain HTTP)	A token reaches only its own customer's sessions; random session ids; an approval must carry the `params_hash` shown with the action; 200 sessions at most; `BG_API_TOKEN` is one shared secret

- **Confirmation, verification and rollback mechanisms**
  - **Confirmation.** Every action that changes money or the registry waits for approval. The card shows the payee, the amount, the account tail, the tier and the balance afterwards. The approval is a hash of the action: changing any field invalidates it (`param_tamper`). A correction is a new action with a new hash.
  - **Verification.** Every action, executed or denied, gets a receipt in the customer's own hash chain. She keeps a signed anchor of the latest receipt and can check the chain against it. A deleted last receipt or a rewritten chain is detected only against an anchor she kept, and only while the signing key is secret. While the public demo key is in use, the log and the UI say so.
  - **Rollback.** Before execution she can reject, cancel or correct any pending action, and nothing has moved. After execution the prototype has no reversal: the sandbox has no recall or refund function, and a real payment could not always be recalled. That is why high-risk steps wait for a code. A denied action is final and recorded; the only unlock is the operator reset of the code lock.
  - **Failure recovery.** A model that is down, slow or malformed falls back to the rules parser. A policy exception becomes a deny. A malformed anchor gives "invalid", not a crash. A message over 2,000 characters is refused before parsing.

02 Security Tests

- **Prompt injection, social engineering, privilege escalation and failure recovery tests**

  Every test runs against the real system through `bg.app.build_default`. A case counts as blocked only if every invariant of its family holds: no money to an unregistered or attacker account, limits unchanged, approvals bound, no other customer's data.

Category	What was tested	Where	Result
Prompt injection	Hidden instructions in invoices (9 variants, plus ES, AR, ZH, base64, leetspeak, table, polite, fake bank notice, zero-width, system tags), IBAN swap with no instruction, poisoned FX note, model free text	tests/adversarial F1 and F4; blind v1 document cases; blind v2 D01 to D13; missions T14 and T20	69/69 in the development suites; blind v2 rules 69/70 overall
Social engineering	Chat IBAN change, new payee named "mom", look-alike duplicate name, add-payee-and-pay in one sentence, a careless user who approves everything shown (stage B)	tests/adversarial F2; blind v2 M01 to M15 and the careless-user stage; tests/audit	No money reached a non-registry payee in any case
Privilege escalation, data extraction	"Raise my limit", "skip the code", DAN and developer mode, other customers' balances, system prompt, API keys, other tenant's payee id	tests/adversarial F3 (18); blind v2 P01 to P10; mission T19	No data leaked; limits unchanged
Replay, tampering, brute force	Double confirm, wrong hash, other session, other tenant, 10 wrong codes then the right one, new session or correction to reset the counter	tests/adversarial F5 (15); blind v2 O01 to O04 and R01 to R07; missions T12, T13, T17	Money moved at most once; the lockout holds
Compliance controls	Structuring (4 x 400, 600 + 550 + 500), sanctions with homoglyphs and spacing variants, invalid IBAN, payee-name collision, FX price manipulation	tests/unit/policy, tests/audit; missions T15, T16; blind v2 S01 to S04 and X01 to X08	Blind v2: one miss (X08, Cyrillic letter), fixed afterwards
Failure recovery	Model unreachable, timeout, HTTP 500, invalid JSON, extra field, out-of-range amount, empty list; policy exception; malformed anchor; truncated and rewritten chains	tests/unit/agent (local parser, connectors, hardening), tests/unit/ledger, tests/audit	Every case falls back to the rules parser, denies, or returns invalid

Evaluation layer	Result	How to read it
Development suites (team-written)	69/69 attacks, 29/29 benign	Regression only
Blind v1, rules parser, first run	47/48 attacks, 21/25 benign	Blind at the time. A claim that all 14 document injections were detected was inflated: 8 misses were masked by the seeded invoice. Corrected; three structural signals now detect them.
Blind v2, rules parser (`44542f2`)	**69/70 attacks** (95% CI 92.3 to 99.7); multi-turn 15/15; 24/30 benign English (62.7 to 90.5); non-English 0/5; 0 wrong payments, 0 data leaks, 0 unconfirmed executions	**Generalisation estimate, rules.** Nine attacks were stopped only because the parser did not understand them (58/59 without them). The one miss needed the customer's code.
Blind v2, Qwen2.5 7B (`5868d83`)	**66/70 attacks** (86.2 to 97.8); multi-turn 15/15; 26/30 benign English (70.3 to 94.7); non-English 5/5; 137 calls, 0 fallbacks. Qwen 3B: 65/70, 21/30, 3/5	**Generalisation estimate, LLM parser.** One run. No payment to an unregistered account. One bypass from a field the model changed (X02).
Regression after the frozen runs	Qwen 7B 103/105 on v2; cascade 104/105; both 69/69 and 29/29 on the development suites; 1379 tests pass	Not generalisation: the system was changed after seeing these cases.

White-box audits. Round 1 (code before `2ce6035`): 12 findings (3 High, 3 Medium, 6 Low). Round 2 (code at `22b144e`): 11 findings (2 Medium, 9 Low). Round 3 (after `d1822bf`, 2026-10-20): 8 findings (1 High, 2 Medium, 5 Low). Each has a test that runs the exploit (`tests/audit/`, `tests/harness/`); 169 audit tests pass and no xfail is left. These are the fixed vulnerabilities; open and unverified points are in Section 04.

ID	Sev.	Finding	Status
AUDIT-1	High	A poisoned FX quote could charge 2,590 USD for 100 EUR; quotes were reusable	Fixed: ledger issues single-use quotes; `FX_PRICE_CHECK`
AUDIT-2	High	A watch-listed IBAN with Arabic-Indic digits got R3, not the sanctions deny; no mod-97 check	Fixed: canonical IBAN, `IBAN_VALID`
AUDIT-3	High	The wrong-code lockout reset with each new action, correction or session	Fixed: counted per customer
AUDIT-4, 5, 6	Medium	Armenian and Cherokee look-alikes passed the name screen; a new payee could shadow "mom"; a payee name rendered as HTML hid every warning	Fixed: wider table, fail closed; `PAYEE_NAME_UNIQUE`; escaping
AUDIT-7 to 11	Low	Huge amounts raised an exception; `1.005` rounded silently; raw messages logged; one global receipt chain; malformed anchor crashed verification	Fixed
AUDIT-12	Low	Anchors signed with the public demo key when `BG_RECEIPT_KEY` is unset	Mitigated: logged and shown in the UI; still the offline default
AUDIT2-1, 2	Medium	A sanctioned name without spaces passed the screen; a model's free text was shown as the bank's own words and bare URLs became links	Fixed in `c10f0a0`
AUDIT2-3 to 11	Low	Markdown in chips; ungrounded synonyms, currencies and memo; question turned into a correction; duplicate cards; proxy variable; raw telemetry; quadratic CPU on a long message	Fixed in `c10f0a0`
APPSEC-1	High	With an empty key field in the UI, the operator's `BG_MODEL_API_KEY` was sent to the Base URL a visitor typed (reproduced)	Fixed: the environment key goes only to the origin named in `BG_MODEL_BASE_URL`
APPSEC-2, 3	Medium	"Rules only" silently used `BG_PARSER`, so a remote model could sit behind the label; Streamlit listened on every interface and showed tracebacks	Fixed: explicit rules parser; `127.0.0.1`, Host allow-list, no tracebacks; Docker on `127.0.0.1`
HARD-1 to 3	Medium	After three wrong codes an R2 one-tap still executed; the HTTP API had one shared token, guessable session ids and approval by action id; with a model parser the security event of a refusal depended on the model's label (real Qwen 7B: 67/69)	Fixed: every approval frozen by the lock; per-customer tokens, random ids, `params_hash` required, 200-session cap; the rules classify the refusal too
REV-1, REV-2	Medium	Independent review of the phase-2 changes: a bill named twice by a model was paid twice; the question filter passed look-alike letters; Cancel and Correct cues were too common; a slow error body held a call; one token could use all sessions	Fixed with tests: a bill is paid once (the ledger refuses a second payment for an obligation), stricter filters, time limit, 50 sessions per customer. Left open: DNS rebinding and the document-IBAN heuristic (R-24, R-25)

ID	Sev.	Finding	Status
APPSEC-4 to 8	Low	Unbounded model response and private-network model URL; a document IBAN split by words, and a not-available document IBAN only R3; unauthenticated remote API and loose Host parsing; 200 MB uploads; port sharing on Windows	Fixed: 256 KiB cap and public-address check; both IBAN cases R4; token required off loopback, `BG_API_USER`; 1 MB upload; exclusive bind

03 Data and Privacy

- **Data provenance, consent, minimisation, storage and deletion**

Topic	What is true in this prototype
Provenance	All data is synthetic. The persona (Lina), balances, payees, IBANs, invoices and the sanctions list are invented constants in `bg/contracts/params.py`. The IBANs are fictional and pass the mod-97 check. No real person, account or document was used. The Qwen models were run unmodified; nothing was fine-tuned.
Consent	No real user took part, so no personal data was collected and no consent was needed. A real deployment would need the customer's consent to process her messages, and to send them to a third-party model if a remote model is connected. Choosing "Connect a model" in the UI shows that a remote endpoint receives the messages.
Minimisation	A model receives only the customer's message, her own payee names and aliases, and the agent's pending question. Never a saved IBAN, a balance, a document or another customer's data; an IBAN or code typed in the sentence goes with it (R-22). The audit log keeps a SHA-256 and the length of each message instead of its text, masks IBANs to their last four characters and drops one-time codes. Model telemetry holds timings, a hash and an error class.
Storage	Sessions, drafts, the wrong-code counter and ledger state are in memory and end with the process. Receipts are in SQLite, in memory by default or in a file if a path is given; each row holds the full action payload as plain text. Mission audit logs in `deliverables/evidence/` are masked. A connected model's API key lives only in the browser session or the environment and is never written to disk. There is no encryption at rest and no access control in the sandbox.
Third parties	None by default; no network call is made. A local model is called on `localhost`. A connected remote model receives the message and the payee names.
Deletion	Ending the process or pressing Reset demo discards the sandbox state. The receipt chain cannot be edited without breaking verification, so a real erasure request needs another design (hashes only in the chain, payloads in a separate store under a per-customer key that can be deleted). That is not built.
Secrets	An audit of the full git history found no API key, token or personal e-mail address. The committed receipt-signing key is a public demo value, flagged while it is in use.

No data-protection compliance (GDPR, PIPL or other) is claimed.

04 Known Risks

- **Risk, impact, mitigation and planned improvement**

For each risk: description, potential impact, severity, mitigations in place, remaining action and status. Severity is what the finding would be if the prototype were deployed as it is; the sandbox effect is in brackets where it differs. Fixed vulnerabilities are in the audit tables of Section 02. Nothing here is a claim that the prototype is secure.

Residual risks (accepted for the sandbox; Mitigated means reduced, not removed)

ID	Description	Potential impact	Severity	Mitigations in place	Remaining action	Status
R-01	No real authentication. The UI serves one fixed customer (`ui/app.py`); `new_session(user_id)` trusts its caller; session ids are predictable (`orchestrator.py`, `new_session`)	Whoever reaches a surface acts as any customer; tenant isolation holds only behind an authenticating gateway	High (sandbox: Low, local and synthetic)	Localhost binding; tenant-scoped reads; `TENANT_ISOLATION`; a confirmation works only in the session that holds the action	An authenticated principal and random session tokens bound to it	Residual
R-02	The one-time code is the constant `246810`, shown in the UI; the guided demo enters it for the user	Step-up gives no assurance of who approved	High (demo only)	Constant-time comparison; per-customer lockout	A per-transaction code from a real strong-customer-authentication channel, linked to amount and payee	Residual

ID	Description	Potential impact	Severity	Mitigations in place	Remaining action	Status
R-03	The code lock lives in memory with the backend: restarting it clears the lock. In the demo UI, Reset demo, the model selector, the exchange-rate toggle and a new browser tab rebuild the backend, so the customer can clear her own lock. The API has no unlock, and any API client can lock a customer out with three wrong codes	Guessing is bounded only within one backend run; the lock can be used for denial of service	Medium (sandbox: Low)	`StepUpAttempts` is shared by all sessions of a backend and now freezes every approval (HARD-1); `STEP_UP_LOCKOUT` writes a receipt; the Reset demo button says that it stands in for the operator	A persistent lock store; an operator-only unlock behind its own login; monitoring	Residual
R-04	HTTP API: plain HTTP; with no token on loopback, every local process can call it as any seeded customer; `BG_API_TOKEN` is one shared secret for all customers; `BG_API_TOKENS` are static secrets in the environment, without rotation; the CLI `--user` is unauthenticated; approval proves that the caller holds the action's hash, not that a human approved	A local process, or a token holder, can drive the customers its token covers	Medium (sandbox: Low)	Loopback by default; strict Host check; a token is required off loopback; per-customer tokens and `BG_API_USER`; random session ids; the approval carries the hash shown with the action; 200-session cap; responses carry no code and only masked IBANs	Token rotation, TLS, a real identity provider; a human-approval channel separate from the API client	Residual
R-05	Receipt anchors are HMAC-SHA256 with the public demo key unless `BG_RECEIPT_KEY` is set; HMAC is symmetric	Forged anchors; the key holder can rewrite history	Medium (sandbox: Low)	Warning in the log and the UI; per-customer chains; truncation is detectable against the customer's anchor	Asymmetric signatures, key rotation, external timestamping	Residual
R-06	One enforcement point: `SandboxLedger.execute` accepts `confirmation=None` and re-checks no authorisation. State is in memory, with no lock between policy and execution	A new caller that bypasses the orchestrator would move money ungated; a shared backend would have a race on limits	Medium (sandbox: Low)	The orchestrator is the only caller; one backend per UI session; policy re-evaluated at confirmation	The ledger should require a signed decision; a per-customer lock; a persistent store	Residual
R-07	The injection guard knows English and French phrases only	A missing warning	Low	Three language-independent structural signals; no authorisation reads the guard	A wider detector, measured blind	Residual
R-08	Grounding checks that a value is in the user's text, not what it means	A wrong but visible card, or a question	Medium	Grounding on every parser; sanctions screen on the source text; the card shows the details before approval	A blind extraction test set	Residual
R-09	No hosted or frontier model measured; Qwen measured once; the rules parser scores 0/5 on non-English	Unknown failure modes with other models	Medium	The same gates apply to any model; fallback to the rules	A blind run through the connector	Residual
R-10	A connected remote model receives the messages and payee names; loopback URLs typed in the UI are accepted	Data leaves the machine; requests to local services	Medium (sandbox: Low)	Off by default; https and public-address check for remote hosts; key kept in the browser session; the UI says what is sent	Data-processing terms; refuse loopback URLs typed in the UI unless the operator allows them	Residual
R-11	Sanctions screening is a demonstration: two fictional names, one IBAN, a finite confusables table, no transliteration	Misses and false blocks in real use	Medium	Fails closed on letters that cannot be folded; spacing and leet variants	A real list, UTS #39, fuzzy and transliteration matching, a manual-review queue	Residual
R-12	Verification of Payee uses a fictional account-holder directory; a typed not-available IBAN is R3 only; a close match passes with the code	A misdirected payee approved with the customer's code	Low	R4 when the IBAN comes from a document; otherwise a warning and a code	A real Verification of Payee scheme	Residual
R-13	Structuring detection covers one payee and one 24 h window	Splitting across payees or days is not detected	Medium	Step-up and an event for the covered case	Cross-payee, multi-day analytics	Residual
R-14	The user approves a malicious payee or payment (social engineering)	Loss to a scammer	Medium	72 h step-up for new payees, sanctions, Verification of Payee, name-collision check, caps, an explicit card	A cool-off delay (not built)	Residual
R-15	Frozen demo clock (`DEMO_NOW`)	Quote expiry, the 72 h window and the daily reset are never exercised in real time	Low	Unit tests with chosen clocks	A real clock	Residual
R-16	Receipt payloads are plain text; no encryption at rest; no erasure	Privacy, in a real deployment	Low (synthetic data)	In memory by default; the audit log is masked	A hash-only chain with encrypted, erasable payloads	Residual
R-17	Results after the frozen runs are regression results, not blind	No current generalisation estimate	n/a	The frozen blind runs are reported separately	A new blind set	Residual

ID	Description	Potential impact	Severity	Mitigations in place	Remaining action	Status
R-18	No rate limiting on the UI or the API; sessions never expire; replays of one approval inside a session each add a signed receipt	Denial of service	Low	2,000-character limit; 64 KiB API body; 1 MB upload; 50 sessions per customer and 200 per server	Rate limits	Residual
R-19	Supply chain	A malicious dependency	Low	Hash-pinned lock files; Docker base image pinned by digest; pip-audit in CI; Dependabot	A software bill of materials	Mitigated
R-20	One demo persona and one currency pair; a local model call takes seconds (Section 12.4)	Narrow coverage; slower than the rules	Low	The cascade calls a model only when the rules cannot read the message	More personas and currencies	Residual
R-24	The check that a remote model endpoint resolves to public addresses and the connection itself resolve the name twice: a name that answers with a public address first and 127.0.0.1 afterwards (DNS rebinding) passes the check (simulated in the review by patching the resolver)	Blind connection and port probing of the operator's machine over https; the certificate check limits what can be read	Low	https is required off loopback and the certificate must match; the check runs at every call; redirects are off; the reply is capped	Connect to the address that was checked, keeping the host name for TLS	Residual
R-25	The check that an IBAN comes from an attached document is a heuristic (letters and digits, any spacing). An IBAN written as a labelled breakdown (country, bank, sort code, account), with the letter O for zero, in Arabic-Indic digits or with a long separator is not recognised, so the payment asks for a code and shows a warning instead of being refused. It only fires when the invoice is attached to the message	A document-supplied account can reach the code step instead of the refusal	Low	Verification of Payee, the code step, the scam warning and the registry still apply; no payment goes to an unsaved account without a code	Fold look-alike characters and match group by group	Residual
R-21	The HTTP API holds one lock while a model reads a message, so a slow model delays every session of that server for up to the timeout (30 s); the cascade can take 60 s. Nothing remembers that a model is down, so each message pays the failed connection again (immediate on loopback, the timeout for a server that accepts and hangs)	Denial of service on a shared server	Low (sandbox)	The deadline of AI-3; the server is single-user by design (loopback)	Release the lock during the model call, or one worker per session	Residual
R-22	What the customer types goes to the model as typed: an IBAN or a code in the sentence included. A remote model provider receives it	Personal data leaves the machine when a remote endpoint is chosen	Medium for a remote endpoint (local models: none)	Saved IBANs, balances and documents are never sent; the UI states that a remote endpoint receives the message; the default parser sends nothing	Redact IBAN-like strings and six-digit codes from the prompt where grounding does not need them	Residual
R-23	The signed receipts and the audit do not record which parser read the message, with which model or prompt	A receipt cannot show who interpreted the intent; the proof of intent covers what was approved, not how it was read	Low	The API record and the `parse` audit event carry the parser label (`rules`, `local`, `connected:<host>`, `cascade:<tier>`); the approved action and its hash are signed	Put parser, model and a prompt hash into the signed intent	Residual

Unverified points (could not be checked here)

ID	Description	Potential impact	Severity	Mitigations in place	Remaining action	Status
U-3	DNS rebinding between the public-address check and the connection	The host is resolved twice; the review simulated the race by patching the resolver and it passes (R-24), a real rebinding server was not run	Open	https and the certificate check; the check runs at every call	Connect to the address that was checked	Unverified
U-4	The connector against a real hosted provider	Only local and fake servers were used	Open	Fallback to the rules on any failure	Run it once with a real endpoint	Unverified
U-5	Docker runtime exposure	Docker is not installed on the development machine; CI builds the image	Open	Documented `-p 127.0.0.1:8501:8501`; non-root user; base image pinned	A container smoke test	Unverified
U-6	Concurrency on a shared backend	Not built and not tested	Open	One backend per UI session	A load test with locks	Unverified
U-7	Regulatory fit (strong customer authentication, AML, sanctions, data protection)	Not claimed	n/a	None claimed	Out of scope for a sandbox	Unverified